UNIVERSIDAD POLITÉCNICA DE SAN LUIS POTOSÍ

Ingeniería en Tecnologías de la Información

Plan de Respuesta
ante Incidentes de Seguridad de la Información

Aarón Emanuel González Díaz

Matrícula: 182447

26 de Octubre de 2026

Sección 1 — Propósito, alcance y clasificación de incidentes

1.1 Propósito

Este documento establece el procedimiento formal que INTERAPAS seguirá para detectar, contener, erradicar y recuperarse de incidentes de seguridad de la información que afecten la confidencialidad, integridad o disponibilidad de sus sistemas comerciales, administrativos y de tecnología operativa (OT), así como para comunicar y documentar cada incidente de forma que el organismo aprenda de él. El plan retoma la estructura de los playbooks de CISA (Federal Government Cybersecurity Incident and Vulnerability Response Playbooks, 2021) por ser una referencia pública, probada y aplicable a organismos operadores de infraestructura crítica, y la adapta a la realidad de INTERAPAS: un organismo con sistemas comerciales que tratan datos de 372,189 usuarios y con un segmento OT que controla el proceso físico de bombeo y distribución de agua.

1.2 Alcance

El plan aplica a todo incidente de seguridad de la información detectado en los sistemas de INTERAPAS dentro del alcance definido en el SGSI propuesto (Unidad de Informática y Sistemas, dependiente de la Dirección General): el portal ciudadano, la plataforma y app de pago INTERAPPAS, el sistema comercial, el Sistema de Información Geográfica (SIG), la plataforma de fraccionadores y los sistemas de supervisión y control de pozos y estaciones de bombeo (OT). Quedan fuera del alcance directo —pero dentro del canal de reporte— los incidentes que ocurran en sistemas de terceros (proveedores, pasarela de pago, plataformas gubernamentales externas como SA7, SICAF, SEVAC o DECLARAGUA) cuando afecten a INTERAPAS.

1.3 Clasificación de incidentes por severidad

La clasificación retoma la misma escala de la matriz de riesgos del SGSI, de modo que un riesgo identificado y un incidente real se puedan comparar directamente.

Nivel	Criterio	Ejemplo en INTERAPAS	Tiempo de respuesta
Crítico	Compromiso o riesgo real de compromiso de la red OT, manipulación de parámetros del proceso físico, o exposición masiva de datos de usuarios.	Bypass de la frontera OT (R06); manipulación de parámetro operacional sin validación (R20).	Inmediato (≤ 1 hora para activar el CSIRT)
Alto	Compromiso de un sistema que trata datos personales o financieros, o escalamiento de privilegios, sin afectación directa al proceso físico.	Escalamiento de privilegios por cookie de rol (R08); inyección SQL (R11).	≤ 4 horas
Medio	Exposición de información interna no crítica o vulnerabilidad explotable con impacto acotado.	Divulgación de artefactos de despliegue (R07); errores verbosos.	≤ 24 horas
Bajo	Hallazgo de riesgo con probabilidad o impacto bajo, sin evidencia de explotación activa.	Fuga menor de metadatos; hallazgos de higiene de configuración.	≤ 5 días hábiles

Sección 2 — Roles y responsabilidades

La respuesta a incidentes en INTERAPAS la coordina un Equipo de Respuesta a Incidentes de Seguridad (CSIRT) integrado por personal de distintas direcciones, no solo de la Unidad de Informática y Sistemas,

porque un incidente —como mostró la auditoría ofensiva— puede escalar del portal de pago hasta la red operativa.

Rol	Responsabilidad
Líder del CSIRT (Jefatura de la Unidad de Informática y Sistemas)	Activa el plan, coordina al equipo, decide el tratamiento y reporta a la Dirección General.
Analista de seguridad / respuesta técnica	Realiza el análisis técnico, la contención y la erradicación; documenta evidencia.
Responsable de sistemas OT (Dirección de Operación y Mantenimiento)	Autoriza y ejecuta acciones de contención en la red operativa; valida que el proceso físico permanezca seguro durante la respuesta.
Responsable de comercialización / datos personales (Dirección de Comercialización)	Evalúa el impacto sobre los datos de usuarios y activa, si corresponde, el Plan de Comunicación de Crisis.
Enlace de comunicación social	Coordina la comunicación externa conforme al Plan de Comunicación de Crisis cuando el incidente lo requiere.
Dirección Jurídica	Evalúa obligaciones legales de notificación (protección de datos personales, transparencia) y resguardo de evidencia con valor probatorio.
Dirección General	Autoriza decisiones de alto impacto (p. ej. suspender un servicio) e informa a la Junta de Gobierno cuando el incidente es crítico.
Órgano Interno de Control	Da seguimiento a que el procedimiento se haya cumplido y a las lecciones aprendidas.

Sección 3 — Preparación, detección y reporte

3.1 Preparación

- Mantener actualizado el inventario de los 20 activos de información del alcance del SGSI, con su propietario y nivel de criticidad.
- Mantener vigente este plan, las listas de contacto del CSIRT y los playbooks operativos, con revisión al menos semestral.
- Asegurar que los sistemas generen bitácoras suficientes (accesos, errores, cambios de configuración) y que se conserven por un plazo mínimo acorde al marco legal aplicable.
- Capacitar al personal de la Unidad de Informática y Sistemas y a los operadores OT en identificación de señales de incidente y en el procedimiento de reporte.
- Mantener un canal de reporte permanente (correo y teléfono del CSIRT) difundido entre el personal.

3.2 Detección y reporte

- Fuentes de detección: alertas de los propios sistemas, reportes del personal, reportes ciudadanos a través de la app INTERAPPAS o del portal de transparencia, notificaciones de terceros (proveedores, CERT nacional) y hallazgos de auditorías o pruebas de seguridad.
- Cualquier persona del organismo que detecte un comportamiento anómalo —una alerta del sistema, un acceso inesperado, una caída del servicio sin causa aparente, un parámetro operativo fuera de rango— debe reportarlo de inmediato al CSIRT, sin intentar remediarlo por su cuenta ni borrar evidencia.
- El reporte debe registrar: fecha y hora, sistema afectado, qué se observó, quién lo detectó y, de ser posible, capturas o bitácoras del momento.

Sección 4 — Análisis y priorización

- El CSIRT confirma si lo reportado es en efecto un incidente (y no un falso positivo) y recaba evidencia inicial sin alterar el sistema afectado.
- Se identifica el o los activos involucrados, el vector probable y el alcance aproximado (cuántos usuarios, qué sistemas, si hay indicios de movimiento hacia la red OT).
- Se clasifica el incidente según la tabla de clasificación (Sección 1) y se activa el tiempo de respuesta correspondiente.
- Se prioriza la atención: un incidente con posible afectación a la red OT o al proceso físico de bombeo se atiende antes que uno limitado a información administrativa, incluso si éste llegó primero.

Sección 5 — Contención

- Aislar el sistema o segmento afectado sin apagarlo cuando sea posible, para preservar evidencia (p. ej. revocar sesiones y tokens comprometidos antes que reiniciar el servidor).
- En incidentes que involucren la frontera OT (como el bypass de IP de origen explotado en la auditoría), bloquear de inmediato el tránsito sospechoso en el perímetro y verificar que los controladores de campo permanezcan en modo seguro.
- Cambiar credenciales y rotar llaves o cookies de sesión potencialmente expuestas.
- Documentar cada acción de contención con hora exacta y responsable, para la fase de análisis post-incidente.

Sección 6 — Erradicación y remediación

- Eliminar la causa raíz identificada en la auditoría ofensiva (por ejemplo: cerrar el endpoint de debug, retirar el archivo de respaldo expuesto, corregir la validación de autorización por objeto, sustituir la verificación de integridad del firmware por una de autenticidad).
- Verificar que no existan artefactos adicionales dejados por el atacante (cuentas creadas, tareas programadas, archivos añadidos).
- Aplicar el control correctivo definido en la matriz de riesgos del SGSI para la amenaza específica, no solo un parche temporal.

Sección 7 — Recuperación

- Restablecer el servicio de forma gradual y supervisada, validando primero en un entorno de prueba cuando el cambio afecte al sistema comercial o a la red OT.
- Confirmar con el responsable del activo (ver tabla de activos del SGSI) que el sistema opera con normalidad antes de darlo por recuperado.
- Mantener vigilancia reforzada (monitoreo adicional) durante al menos 72 horas después de la recuperación de un incidente Crítico o Alto.
- Informar a los usuarios afectados y, de corresponder, restablecer los servicios que se hayan suspendido de forma preventiva (p. ej. el módulo de pagos en línea).

Sección 8 — Coordinación y comunicación

Para incidentes de nivel Alto o Crítico, el Líder del CSIRT activa en paralelo el Plan de Comunicación de Crisis de INTERAPAS: se designa un vocero único, se emite un mensaje de contención inicial en un plazo máximo de 2 horas y se mantiene informada a la Dirección General y, cuando el incidente lo amerite, a la Junta de Gobierno. La Dirección Jurídica evalúa si el incidente obliga a notificar a alguna autoridad (por ejemplo, en materia de protección de datos personales) dentro de los plazos legales aplicables. La coordinación con proveedores externos (pasarela de pago, fabricante de equipos OT) sigue el canal de contacto establecido en los contratos de soporte vigentes.

Sección 9 — Playbooks operativos

Se definen seis playbooks (mínimo requerido: cinco), construidos a partir de los escenarios reales identificados en la auditoría ofensiva a INTERAFAS-LAB, siguiendo la estructura de los playbooks de CISA: detección, contención, erradicación y recuperación para cada familia de incidente.

PB-01 — Acceso indebido a información de usuarios (IDOR / BOLA)

Incidente (CISA IR Playbook)

Escenario: Un usuario autenticado modifica un identificador en la URL o en una solicitud (número de cuenta, folio de expediente) y accede a datos de otro usuario que no le pertenecen.

Relación con la auditoría: Hallazgos 03, 11 y 12 de la auditoría ofensiva (riesgos R01 y R03 del SGSI).

Detección	Picos de solicitudes con IDs secuenciales desde una misma sesión; reportes de usuarios que ven datos que no son suyos.
Contención	Revocar la sesión del usuario que originó las solicitudes anómalas; bloquear temporalmente el endpoint afectado si el volumen de acceso indebido es alto.
Erradicación	Implementar validación de autorización por objeto (verificar que el recurso solicitado pertenece al usuario autenticado) y sustituir identificadores secuenciales por valores no predecibles.
Recuperación	Reactivar el endpoint corregido; auditar qué registros fueron consultados de forma indebida y notificar a los usuarios afectados si procede.

PB-02 — Fraude en el módulo de pagos

Incidente (CISA IR Playbook)

Escenario: Un usuario altera el monto de pago antes de enviarlo al servidor, aprovechando que el sistema confía en el valor recibido del cliente en lugar de recalcularlo.

Relación con la auditoría: Hallazgo 13 de la auditoría ofensiva (riesgos R02 y R14 del SGSI).

Detección	Discrepancias entre el monto facturado y el monto efectivamente cobrado; alertas de conciliación diaria del sistema comercial.
Contención	Suspender temporalmente el módulo de pago afectado o forzar la verificación manual de transacciones mientras se corrige, para no seguir acumulando pérdida.
Erradicación	Recalcular el monto siempre en el servidor a partir del adeudo real registrado en el padrón, nunca a partir de lo que envía el cliente.
Recuperación	Reactivar el módulo; conciliar y, de ser necesario, corregir los montos de los pagos procesados durante la ventana del incidente.

PB-03 — Escalamiento de privilegios y robo de sesión

Incidente (CISA IR Playbook)

Escenario: Un atacante modifica una cookie de rol o aprovecha una sesión no regenerada tras el inicio de sesión para obtener privilegios administrativos sobre el portal.

Relación con la auditoría: Hallazgos 06 y 10 de la auditoría ofensiva (riesgo R08 del SGSI).

Detección	Cuentas con actividad administrativa que no corresponde a su rol registrado; inicios de sesión simultáneos desde ubicaciones distintas para una misma cuenta.
Contención	Forzar el cierre de todas las sesiones activas de la cuenta comprometida y bloquearla temporalmente.
Erradicación	Determinar el rol del usuario siempre en el servidor (nunca en una cookie del cliente); regenerar el identificador de sesión en cada inicio de sesión; migrar el hash de contraseñas a un algoritmo robusto (bcrypt/argon2).

Recuperación	Restablecer credenciales del usuario afectado; revisar bitácoras para identificar cualquier acción realizada con los privilegios obtenidos indebidamente.

PB-04 — Vulneración de la frontera hacia la red operativa (OT)

Incidente (CISA IR Playbook) con escalamiento obligatorio a OT

Escenario: Un atacante manipula un encabezado de red (X-Forwarded-For) para hacerse pasar por un equipo interno autorizado y obtener acceso al segmento OT que supervisa pozos y estaciones de bombeo.

Relación con la auditoría: Hallazgo 16 de la auditoría ofensiva (riesgo R06 del SGSI, el de mayor nivel en la matriz).

Detección	Tráfico hacia la red OT proveniente de un origen que no coincide con el inventario de equipos autorizados; accesos fuera del horario operativo habitual.
Contención	Bloquear de inmediato el origen sospechoso en el perímetro; aislar el segmento OT del resto de la red si hay indicio de movimiento lateral; notificar sin demora al responsable de Operación y Mantenimiento.
Erradicación	Corregir la validación de origen en el perímetro para que la dirección IP real se determine en el proxy y no se acepte un encabezado enviado por el cliente.
Recuperación	Restablecer el tránsito legítimo; verificar con el personal de Operación que los equipos de campo no fueron alterados durante la ventana de exposición.

PB-05 — Firmware o actualización manipulada en equipos de campo

Incidente (CISA IR Playbook) con activación de contención física

Escenario: Se detecta o se sospecha que un archivo de firmware fue reemplazado o alterado antes de instalarse en un controlador de pozo o estación de bombeo, o que un parámetro operativo fue modificado fuera de su rango de ingeniería.

Relación con la auditoría: Hallazgos 18 y 20 de la auditoría ofensiva (riesgos R05, R19 y R20 del SGSI; este último es el escenario de mayor impacto físico detectado).

Detección	Alertas de parámetros fuera de rango (presión, nivel) en el sistema de supervisión; discrepancia entre la huella de integridad esperada y la del archivo de firmware instalado.
Contención	Poner el equipo afectado en modo seguro o detener la actualización en curso; impedir que el parámetro manipulado se propague a otros equipos de la misma estación.
Erradicación	Sustituir la validación de integridad (que solo confirma que el archivo no cambió en tránsito) por una validación de autenticidad con firma del fabricante; añadir validación de rango de ingeniería e interlocks independientes de software antes de aplicar cualquier parámetro.
Recuperación	Reinstalar un firmware verificado; devolver el parámetro operativo a su valor seguro con doble aprobación; confirmar con Operación y Mantenimiento que el proceso físico opera con normalidad antes de cerrar el incidente.

PB-06 — Vulnerabilidad reportada o descubierta antes de ser explotada

Vulnerabilidad (CISA Vulnerability Response Playbook)

Escenario: Una vulnerabilidad (propia o de un componente de terceros) se identifica mediante monitoreo, una auditoría interna o un aviso externo, sin evidencia de que haya sido explotada todavía.

Relación con la auditoría: Aplica a cualquiera de los 20 hallazgos de la auditoría ofensiva mientras se encuentran en fase de remediación programada, y a futuras vulnerabilidades que se identifiquen en componentes de software o en equipos OT.

Detección	Aviso de un boletín de seguridad del fabricante, hallazgo de un análisis de vulnerabilidades programado, o reporte responsable de un tercero.

Contención	No aplica una contención de emergencia; se evalúa el riesgo de explotación y se decide si amerita una mitigación temporal mientras se aplica la corrección definitiva.
Erradicación	Aplicar el parche o la corrección siguiendo el proceso de gestión de cambios, priorizando según la severidad (CISA Vulnerability Response Playbook) y el nivel de riesgo que esa vulnerabilidad representa en la matriz del SGSI.
Recuperación	Verificar que la corrección se aplicó correctamente y documentarla en el inventario de vulnerabilidades del organismo.

Sección 10 — Post-incidente y mejora

Cerrar un incidente no es apagar la alerta: cada incidente Alto o Crítico debe dejar una lección documentada, igual que la fase de mejora continua del SGSI (ciclo PDCA) lo hace con las políticas que no cumplieron del todo en la verificación.

- En un plazo máximo de 10 días hábiles tras el cierre de un incidente Alto o Crítico, el CSIRT elabora un informe post-incidente: cronología, causa raíz, impacto real, acciones tomadas y tiempo de respuesta frente a lo establecido en la Sección 1.
- El informe se presenta a la Dirección General y, cuando el incidente fue Crítico, se informa a la Junta de Gobierno en su siguiente sesión.
- Las lecciones aprendidas se incorporan a la matriz de riesgos del SGSI (ajustando probabilidad o impacto si el incidente reveló que un riesgo estaba mal estimado) y, cuando corresponde, a una nueva política funcional o a la actualización de una existente —siguiendo el mismo mecanismo de mejora continua descrito en la Sección 10 del documento de gobernanza ISO/IEC 27001.
- Se actualiza el playbook correspondiente si el incidente reveló un paso faltante o un tiempo de respuesta poco realista.
- Métricas de seguimiento sugeridas: número de incidentes por nivel y por trimestre, tiempo medio de detección, tiempo medio de contención y porcentaje de incidentes con informe post-incidente completado dentro del plazo.